

- AWS Hub and Spoke — Transit Gateway, Palo Alto NGFW, Network Firewall & VPC Routing
 - Table of Contents
 - 1. Mental Model — The Full Picture
 - 2. Transit Gateway (TGW) — The Central Hub
 - Appliance Mode — Why It Matters
 - 3. VPCs in the Design
 - 3a. Inspection VPC (the critical one)
 - 3b. Spoke VPCs
 - 3c. Egress VPC (Centralized Internet Egress)
 - 3d. Shared Services VPC (Optional)
 - 4. OnPrem Connectivity — S2S VPN vs Direct Connect
 - Site-to-Site VPN (S2S VPN)
 - AWS Direct Connect (DX)
 - Best Practice for BFSI / Enterprise
 - 5. TGW Route Tables — The Core of Traffic Steering
 - Route Table 1: Pre-Inspection RT
 - Route Table 2: Post-Inspection RT
 - Route Table 3: Egress RT (Optional, for Egress VPC)
 - 6. Traffic Flow — Step by Step
 - 6a. East-West: Spoke VPC A → Spoke VPC B
 - 6b. North-South: OnPrem → Spoke VPC (Ingress)
 - 6c. North-South: Spoke VPC → Internet (Egress)
 - 6d. Internet → Inbound (Ingress from Internet — e.g. public-facing API)
 - 7. Palo Alto VM-Series NGFW in AWS
 - Deployment Model
 - What Palo Alto Inspects
 - SSL/TLS Decryption — How It Works
 - 8. Gateway Load Balancer (GWLB)
 - Key Properties
 - Why GENEVE (not just forwarding)?
 - GWLB Endpoint (GWLB_E)
 - 9. AWS Network Firewall vs Palo Alto
 - 10. Encryption — Every Hop
 - 11. VPC Route Table Design — Complete Reference
 - Spoke VPC Route Table (any spoke)
 - Inspection VPC — TGW ENI Subnet Route Table (ingress side)

- [Inspection VPC — Firewall Subnet Route Table \(Palo Alto's subnet\)](#)
- [Inspection VPC — Return Subnet Route Table \(egress side, after inspection\)](#)
- [Egress VPC — Private Subnet Route Table \(NAT subnet\)](#)
- [Egress VPC — Public Subnet Route Table \(NAT GW's subnet\)](#)
- [12. Full Topology Diagram](#)
- [13. Key Interview Points to Memorize](#)
- [14. How to Answer in the Interview](#)

AWS Hub and Spoke — Transit Gateway, Palo Alto NGFW, Network Firewall & VPC Routing

Topic: Network Security Architecture | Hub-Spoke with TGW + Inspection VPC

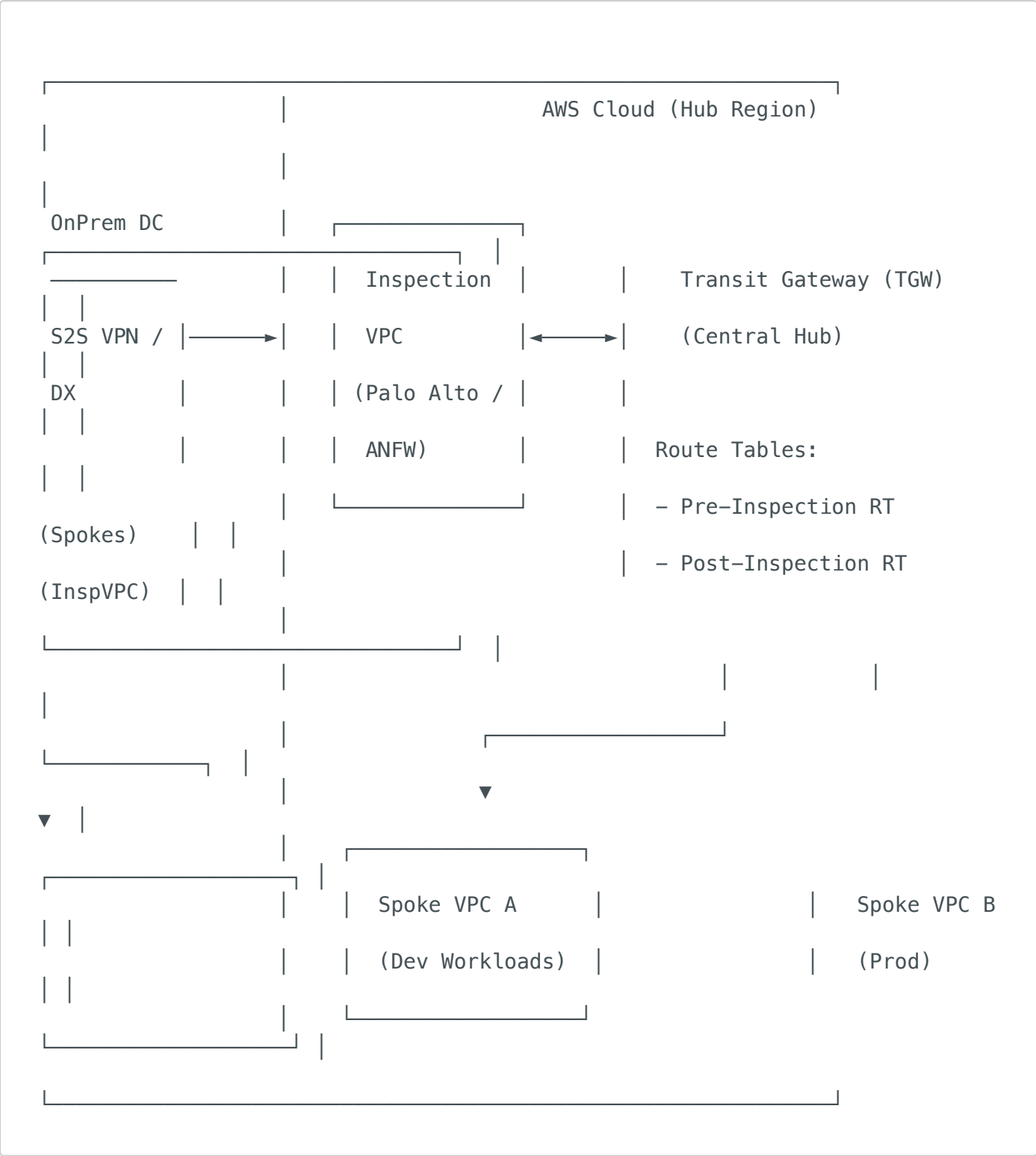
Use Case: OnPrem (S2S VPN / Direct Connect) to AWS Cloud with centralized packet inspection

Prepared by: Pushparaj Naik

Table of Contents

- [1. Mental Model — The Full Picture](#)
- [2. Transit Gateway \(TGW\) — The Central Hub](#)
- [3. VPCs in the Design](#)
- [4. OnPrem Connectivity — S2S VPN vs Direct Connect](#)
- [5. TGW Route Tables — The Core of Traffic Steering](#)
- [6. Traffic Flow — Step by Step](#)
- [7. Palo Alto VM-Series NGFW in AWS](#)
- [8. Gateway Load Balancer \(GWLB\)](#)
- [9. AWS Network Firewall vs Palo Alto](#)
- [10. Encryption — Every Hop](#)
- [11. VPC Route Table Design — Complete Reference](#)
- [12. Full Topology Diagram](#)
- [13. Key Interview Points to Memorize](#)
- [14. How to Answer in the Interview](#)

1. Mental Model — The Full Picture



Core principle: No spoke VPC has a direct Internet Gateway. All traffic — East-West (spoke-to-spoke), North-South (OnPrem↔Cloud), and Internet-bound — is forced through the TGW → Inspection VPC → Palo Alto NGFW before reaching its destination.

2. Transit Gateway (TGW) — The Central Hub

TGW is a **regional, managed network hub**. Every VPC and VPN/DX attachment connects to it.

Property	Detail
Attachments	VPC, VPN, Direct Connect Gateway, TGW Peering
Route Tables	Multiple per TGW; controls where traffic goes next
Propagation	Routes auto-learned from attachments
Association	Each attachment is associated to exactly ONE route table
Appliance Mode	Must be enabled on Inspection VPC attachment — ensures flow symmetry for stateful firewalls
Bandwidth	Up to 50 Gbps per AZ per TGW
Multi-account	Shared via AWS Resource Access Manager (RAM) across accounts

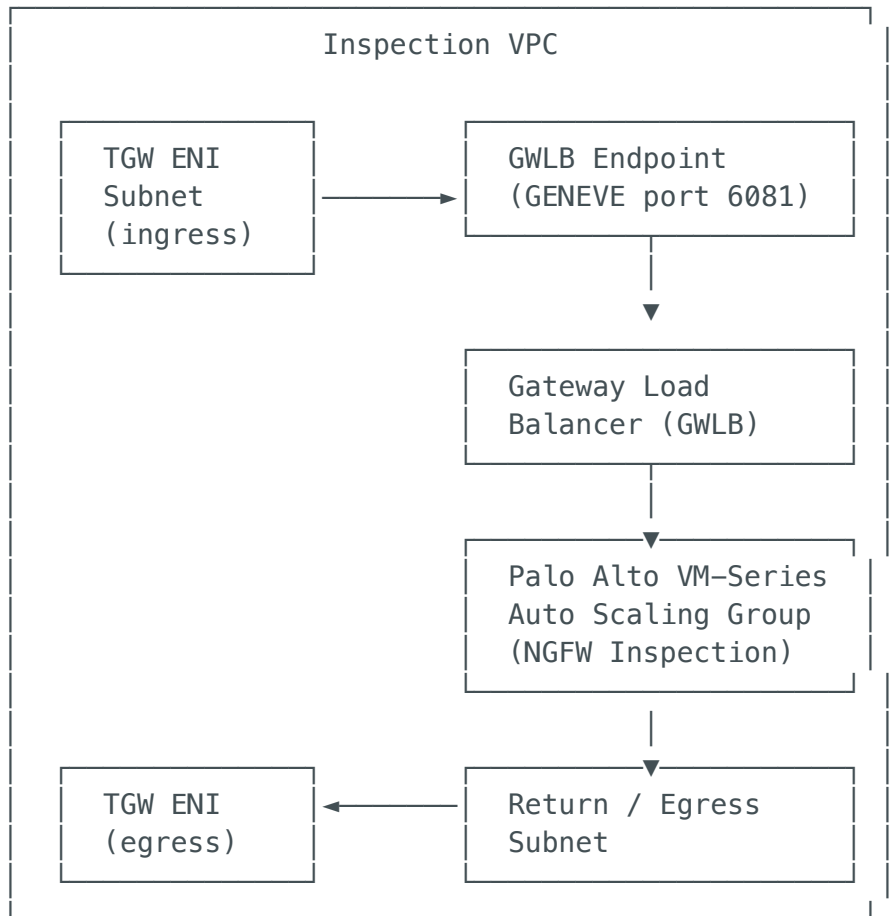
Appliance Mode — Why It Matters

Without Appliance Mode, TGW may send the forward and return path of the same TCP flow to **different firewall instances** in different AZs — breaking stateful inspection. Appliance Mode pins both directions to the same AZ, ensuring the same Palo Alto instance sees both directions of a flow.

3. VPCs in the Design

3a. Inspection VPC (the critical one)

This is where **ALL traffic is forced through** before it reaches its destination.



3b. Spoke VPCs

- Production, Dev, Staging workloads live here
- **No Internet Gateway** attached
- All routes point to TGW
- Spoke VPCs never communicate directly with each other — always via TGW → Inspection VPC → TGW → destination

3c. Egress VPC (Centralized Internet Egress)

- Contains NAT Gateway + Internet Gateway
- All internet-bound traffic from spokes is inspected first, then sent here for NAT
- One Elastic IP per AZ — provides predictable outbound IPs for firewall whitelisting

3d. Shared Services VPC (Optional)

- DNS resolvers (Route 53 Resolver), Active Directory, internal tooling

- Accessible from all spokes via TGW routing
-

4. OnPrem Connectivity — S2S VPN vs Direct Connect

Site-to-Site VPN (S2S VPN)

- **Protocol:** IPSec tunnel between Customer Gateway (your router/ASA/Palo Alto) and TGW VPN attachment
- **Encryption:** IKEv2 with AES-256-GCM, SHA-256, DH Group 14/19/20/21
- **HA:** Two tunnels per VPN connection (active/passive) for redundancy
- **Bandwidth:** Up to 1.25 Gbps per tunnel
- **Transport:** Over the public internet — encrypted but latency is variable
- **Use case:** Cost-effective, quick to set up, good for backup/DR

OnPrem Router —(IPSec / IKEv2 / AES-256-GCM)—> TGW VPN Attachment

AWS Direct Connect (DX)

- **Physical:** Dedicated private fiber from OnPrem colocation to AWS DX location
- **IMPORTANT:** DX itself is **NOT encrypted by default** — it is private (no internet routing) but the data is in cleartext on the wire
- **To encrypt DX — two options:**
 1. **MACsec (IEEE 802.1AE):** Layer 2 encryption, requires DX dedicated connection (1G/10G/100G) and MACsec-capable router at both ends. AES-256-GCM at line rate.
 2. **IPSec VPN over DX:** Run an IPSec tunnel over the DX private VIF — adds encryption but adds overhead and reduces effective throughput
- **Bandwidth:** 1G, 10G, 100G dedicated; hosted connections (50Mbps–10G) via partner
- **Latency:** Consistent, sub-millisecond predictable — ideal for BFSI, real-time trading, large data transfers
- **Resilience:** Two DX connections from different providers/locations for HA

Option 1: MACsec on DX

OnPrem Router —(MACsec L2 AES-256)→ DX Location → DX Gateway → TGW

Option 2: IPSec over DX

OnPrem Router —(DX private link)→ DX GW → TGW VGW —(IPSec VPN overlay)→ TGW

Best Practice for BFSI / Enterprise

Primary: Direct Connect (10G) with MACsec + BGP routing

Secondary: S2S VPN over internet (IPSec IKEv2) as automatic failover

Both terminate on TGW – BGP preference steers traffic to DX

5. TGW Route Tables – The Core of Traffic Steering

This is the most important section. Traffic inspection is achieved **purely through TGW route table manipulation** — forcing all traffic through the Inspection VPC attachment before it reaches its destination.

You create **2-3 separate TGW Route Tables**:

Route Table 1: Pre-Inspection RT

Associated to: All Spoke VPC attachments + OnPrem VPN/DX attachments

Purpose: Force all traffic to the Inspection VPC first — no direct spoke-to-spoke communication

Destination		Next Hop
0.0.0.0/0	→	Inspection VPC TGW attachment
10.0.0.0/8	→	Inspection VPC TGW attachment
172.16.0.0/12	→	Inspection VPC TGW attachment
192.168.0.0/16	→	Inspection VPC TGW attachment

Effect: Any packet leaving a spoke VPC or arriving from OnPrem is forwarded to the Inspection VPC before going anywhere else.

Route Table 2: Post-Inspection RT

Associated to: Inspection VPC TGW attachment

Purpose: After Palo Alto approves the packet, route it to the actual destination

Destination		Next Hop
10.1.0.0/16	→	Spoke VPC A TGW attachment
10.2.0.0/16	→	Spoke VPC B TGW attachment
10.3.0.0/16	→	Spoke VPC C TGW attachment
172.16.0.0/12	→	VPN/DX attachment (back to OnPrem)
0.0.0.0/0	→	Egress VPC TGW attachment (internet-bound)

Effect: Approved traffic is forwarded to the real destination after inspection.

Route Table 3: Egress RT (Optional, for Egress VPC)

Associated to: Egress VPC TGW attachment

Purpose: Return traffic from internet back into TGW

Destination		Next Hop
10.0.0.0/8	→	Inspection VPC TGW attachment (inspect return traffic too)

6. Traffic Flow — Step by Step

6a. East-West: Spoke VPC A → Spoke VPC B

Step 1: EC2 (10.1.5.10) in Spoke A sends packet to EC2 (10.2.5.20) in Spoke B

Step 2: Spoke A route table: 10.0.0.0/8 → TGW

Step 3: TGW receives packet; checks Spoke A attachment's associated RT
→ Pre-Inspection RT: next hop = Inspection VPC attachment

Step 4: Packet arrives at Inspection VPC TGW ENI subnet

Step 5: Inspection VPC route table: 0.0.0.0/0 → GWLB Endpoint

Step 6: GWLB encapsulates in GENEVE, sends to Palo Alto instance

Step 7: Palo Alto performs:

- App-ID (what application is this?)
- Threat Prevention (IPS/IDS checks)
- Security policy evaluation (zone: Trust → Trust)
- Logging to Panorama / SIEM

Step 8: Palo Alto allows packet → returns to GWLB

Step 9: GWLB decapsulates GENEVE, sends to return subnet

Step 10: Return subnet route table: 0.0.0.0/0 → TGW

Step 11: TGW receives packet; checks Inspection VPC attachment's associated RT
→ Post-Inspection RT: 10.2.0.0/16 → Spoke B attachment

Step 12: Packet delivered to EC2 (10.2.5.20) in Spoke B ✓

6b. North-South: OnPrem → Spoke VPC (Ingress)

Step 1: OnPrem server sends packet over IPsec tunnel (encrypted on wire)

Step 2: TGW VPN attachment decrypts the IPsec packet, extracts inner IP packet

Step 3: TGW checks VPN attachment's associated RT → Pre-Inspection RT
→ Next hop: Inspection VPC attachment

Step 4: Packet enters Inspection VPC, hits GWLB endpoint

Step 5: Palo Alto inspects (IPS, URL filter, App-ID, threat prevention)
Zone policy: OnPrem-zone → Cloud-zone

Step 6: Approved → back through GWLB → return subnet → TGW

Step 7: Post-Inspection RT routes to correct Spoke VPC attachment

Step 8: Packet arrives at destination EC2 in Spoke VPC ✓

6c. North-South: Spoke VPC → Internet (Egress)

Step 1: EC2 sends packet to public IP (0.0.0.0/0)

Step 2: Spoke VPC route table: 0.0.0.0/0 → TGW

Step 3: Pre-Inspection RT → Inspection VPC attachment

Step 4: GWLB → Palo Alto:

- URL Filtering (block malicious/unauthorized sites)
- Data Loss Prevention (DLP)
- Threat Prevention
- SSL Decryption (decrypt → inspect → re-encrypt)

Step 5: Approved → return subnet → TGW
Step 6: Post-Inspection RT: 0.0.0.0/0 → Egress VPC attachment
Step 7: Egress VPC: private subnet route 0.0.0.0/0 → NAT Gateway
Step 8: NAT Gateway source-NATted to Elastic IP → Internet Gateway → Internet ✓

6d. Internet → Inbound (Ingress from Internet — e.g. public-facing API)

Step 1: Internet traffic hits ALB/NLB in public subnet of Egress/Ingress VPC
Step 2: ALB forwards to internal target → TGW
Step 3: TGW → Pre-Inspection (or dedicated Ingress RT) → Inspection VPC
Step 4: Palo Alto inspects inbound (WAF-like L7 rules, IPS, geo-blocking)
Step 5: Approved → Post-Inspection RT → Spoke VPC → EC2 target ✓

7. Palo Alto VM-Series NGFW in AWS

Deployment Model

- Runs as **EC2 instances** in the Inspection VPC
- Instance families: **m5.xlarge** (2 Gbps) → **c5n.18xlarge** (100 Gbps+)
- Two ENIs per instance:
 - **Management ENI** (mgmt subnet, out-of-band, no data traffic)
 - **Dataplane ENI** (firewall subnet, GWLB-connected for traffic)
- Deployed in **Auto Scaling Group** behind a **Gateway Load Balancer**
- **Panorama** provides centralized policy management across all instances and regions

What Palo Alto Inspects

Feature	What It Does
App-ID	Identifies application by behavior regardless of port (e.g., Zoom over port 443)

Feature	What It Does
User-ID	Maps traffic to Active Directory username via LDAP/WMI/syslog
Content-ID	IPS signatures, antivirus, DNS security, file blocking
URL Filtering	PAN-DB cloud database — blocks malicious, phishing, C2 domains
SSL/TLS Decryption	Decrypts TLS 1.3, inspects plaintext payload, re-encrypts and forwards
Threat Prevention	Blocks exploits, C2 callbacks, malware downloads, buffer overflows
Zone-Based Policies	Trust → Untrust → DMZ explicit allow/deny rules
Wildfire	Cloud sandboxing — unknown files submitted for zero-day analysis
DoS Protection	Rate limiting, SYN flood protection, zone-based DoS profiles

SSL/TLS Decryption — How It Works

Client (EC2) —TLS 1.3→ Palo Alto intercepts

- Terminates TLS connection from client
- Decrypts and inspects cleartext payload
- Re-signs certificate with internal CA
- Establishes new TLS connection to server

Requirement: Internal CA cert deployed to all endpoints via GP0/SSM so endpoints trust the re-signed certificates

8. Gateway Load Balancer (GWLb)

GWLb is the AWS service that makes transparent firewall insertion possible. Without it, you would need manual routing hacks to redirect traffic to firewall instances.

Key Properties

Property	Detail
Protocol	GENEVE encapsulation (UDP port 6081)
Layer	Operates at Layer 3 — preserves original source/destination IP
Session Affinity	3-tuple or 5-tuple hash — same flow always goes to same firewall instance
Health Checks	Automatically removes unhealthy firewall instances
Scaling	Distributes flows across all healthy Palo Alto instances in ASG
Transparency	Firewall sees real client/server IPs — no SNAT required

Why GENEVE (not just forwarding)?

GENEVE wraps the original L3 packet with metadata. The firewall receives:

- The **original packet** with real src/dst IPs untouched
- GWLB metadata in the GENEVE header

The firewall can thus apply policy based on real source/destination — then returns the (possibly modified) packet to GWLB which strips the GENEVE wrapper and forwards the original.

GWLB Endpoint (GWLBBe)

A VPC endpoint that appears in the Inspection VPC's route table as a next-hop target. Traffic sent to a GWLBBe is automatically forwarded to the GWLB → Palo Alto for inspection.

9. AWS Network Firewall vs Palo Alto

Feature	Palo Alto VM-Series	AWS Network Firewall
L7 App-ID	Yes — 3000+ app signatures	No — port-based only
TLS Inspection	Yes	Yes

Feature	Palo Alto VM-Series	AWS Network Firewall
IPS Engine	Palo Alto Threat Prevention	Suricata-compatible open rules
URL Filtering	Yes — PAN-DB (cloud DB)	Yes — domain/URL lists
User-ID	Yes — AD integration	No
Wildfire Sandbox	Yes	No
DLP	Yes	No
Management	Panorama (centralized)	AWS Firewall Manager
Cost	Higher (\$\$\$) — EC2 + licensing	Lower (\$\$) — per GB + endpoint
Scaling	GWLB + ASG (you manage)	AWS auto-managed
Deployment	EC2 in your VPC	AWS-managed service endpoints
Multi-region	Panorama + per-region TGW	AWS Firewall Manager policies

When to use Palo Alto: BFSI, regulated industries, enterprise with existing Palo Alto on-prem (unified policy), advanced L7 needs, User-ID, Wildfire.

When to use AWS Network Firewall: Cost-sensitive, AWS-native preference, basic IPS/domain filtering, simpler compliance requirements.

10. Encryption — Every Hop

Hop	Encryption Mechanism
OnPrem → TGW (VPN)	IPSec IKEv2 — AES-256-GCM, SHA-256, DH Grp 20
OnPrem → DX Location	MACsec (IEEE 802.1AE) — AES-256 at Layer 2 OR: IPSec VPN tunnel layered over DX private VIF
DX Location → TGW	AWS backbone (private — not public internet)
TGW → Inspection VPC	AWS backbone (encrypted at rest in transit)
Inspection VPC (PA)	TLS Decryption — terminates TLS, inspects, re-encrypts
Spoke VPC ↔ Spoke VPC	Application-level TLS 1.2/1.3 (end-to-end)
Data at Rest (EBS/S3)	AES-256 via KMS (CMK) — mandatory in BFSI

Key BFSI requirement: Even though DX is private (no internet traversal), regulators (RBI, SEBI, PCI-DSS) often require encryption in transit. MACsec satisfies this at Layer 2 without the overhead of IPSec.

11. VPC Route Table Design – Complete Reference

Spoke VPC Route Table (any spoke)

Destination	Target	Notes
10.0.0.0/8 →	tgw-xxxxxxx	All RFC1918 via TGW
172.16.0.0/12→	tgw-xxxxxxx	All RFC1918 via TGW
192.168.0.0/16→	tgw-xxxxxxx	All RFC1918 via TGW
0.0.0.0/0 → (centralized egress)	tgw-xxxxxxx	Internet also via TGW

NOTE: No IGW, no NAT GW in spoke VPCs

Inspection VPC – TGW ENI Subnet Route Table (ingress side)

Destination	Target	Notes
0.0.0.0/0 → → Palo Alto	gwlbe-xxxxxxx	All traffic to GWLB Endpoint

Inspection VPC – Firewall Subnet Route Table (Palo Alto's subnet)

Destination	Target	Notes
0.0.0.0/0 GWLb	→ gwlbe-xxxxxxx	Return traffic back through

Inspection VPC — Return Subnet Route Table (egress side, after inspection)

Destination	Target	Notes
0.0.0.0/0 TGW	→ tgw-xxxxxxx	Return approved traffic to

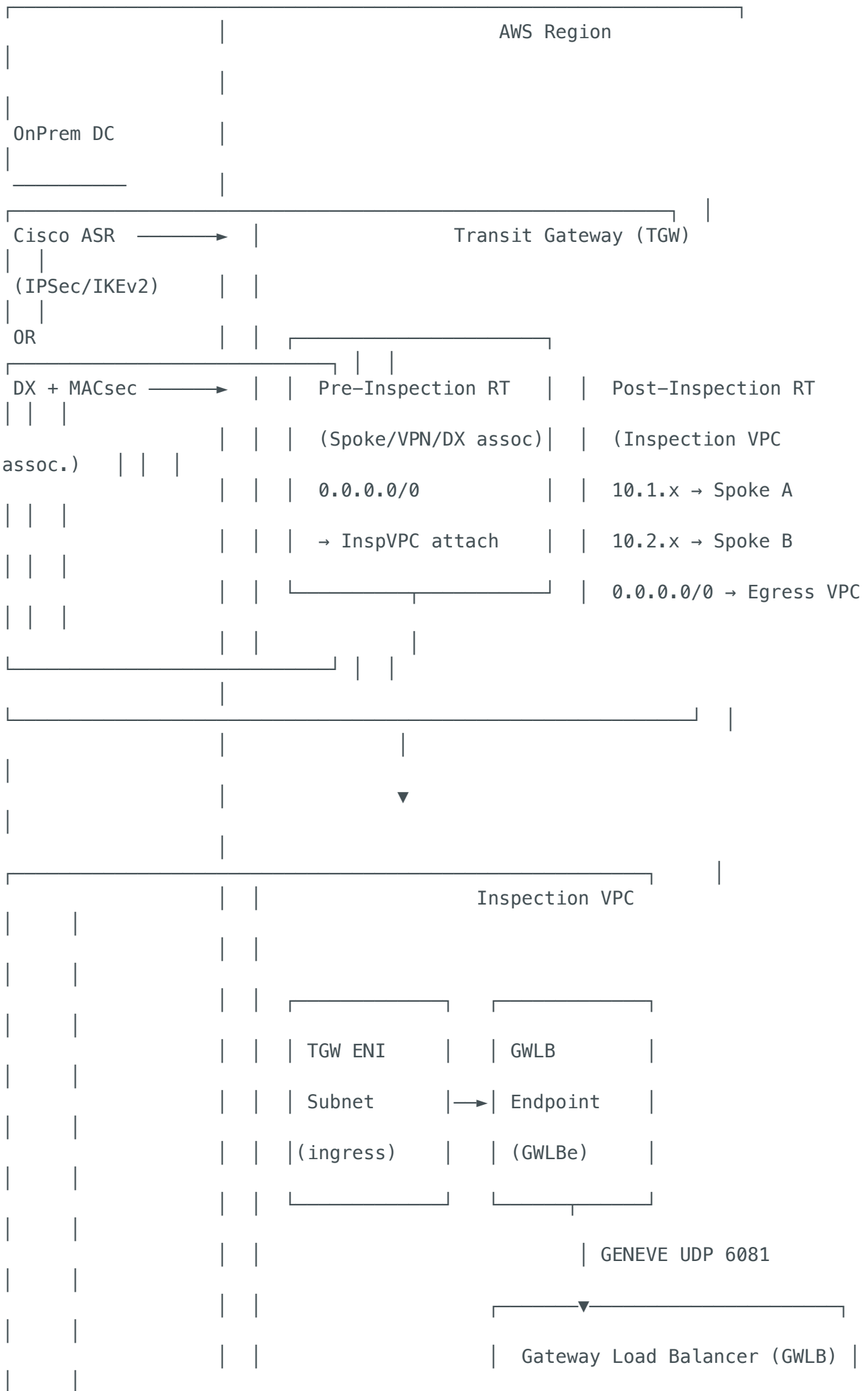
Egress VPC — Private Subnet Route Table (NAT subnet)

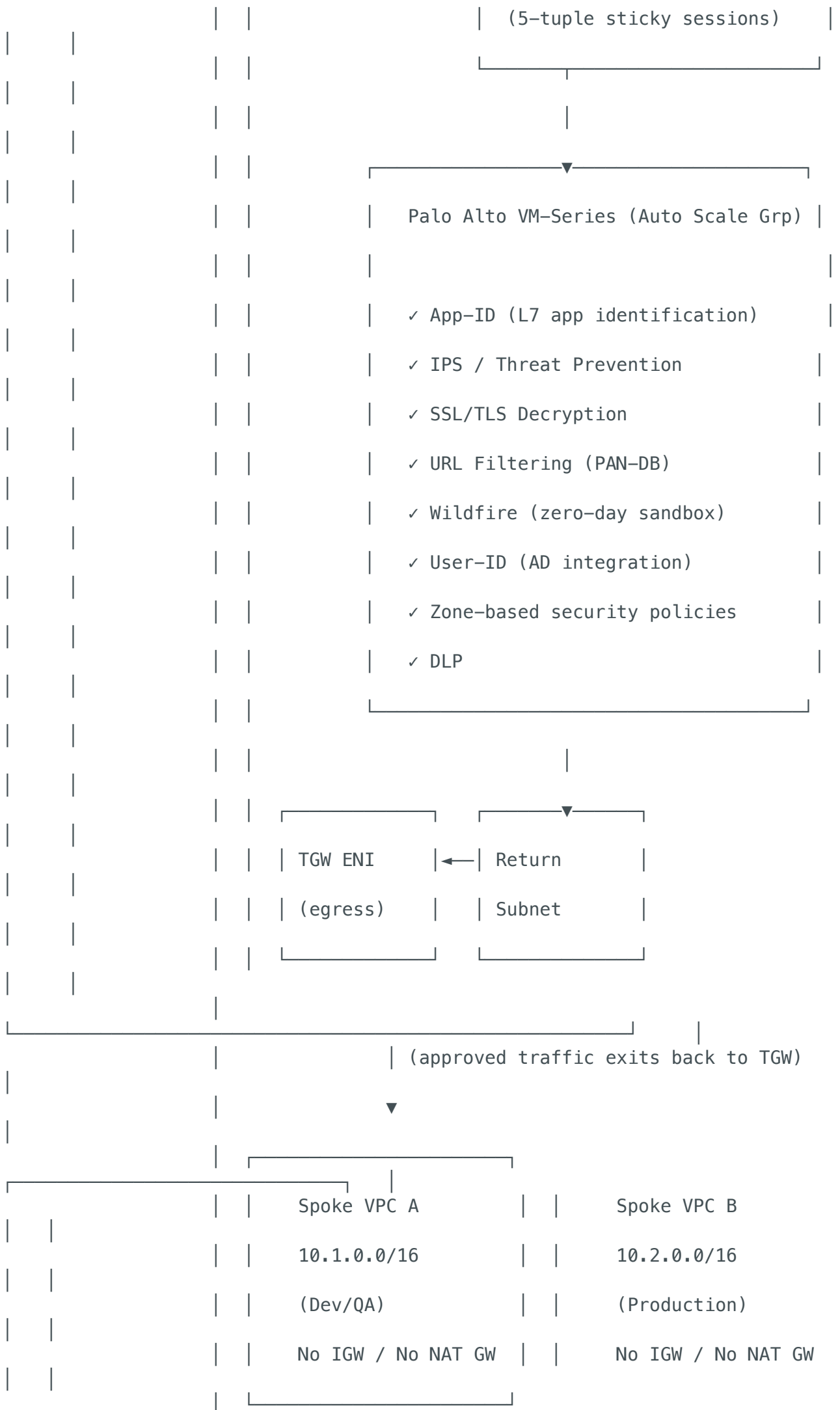
Destination	Target	Notes
0.0.0.0/0	→ nat-xxxxxxx	Outbound internet via NAT GW
10.0.0.0/8	→ tgw-xxxxxxx	Return path back to spokes

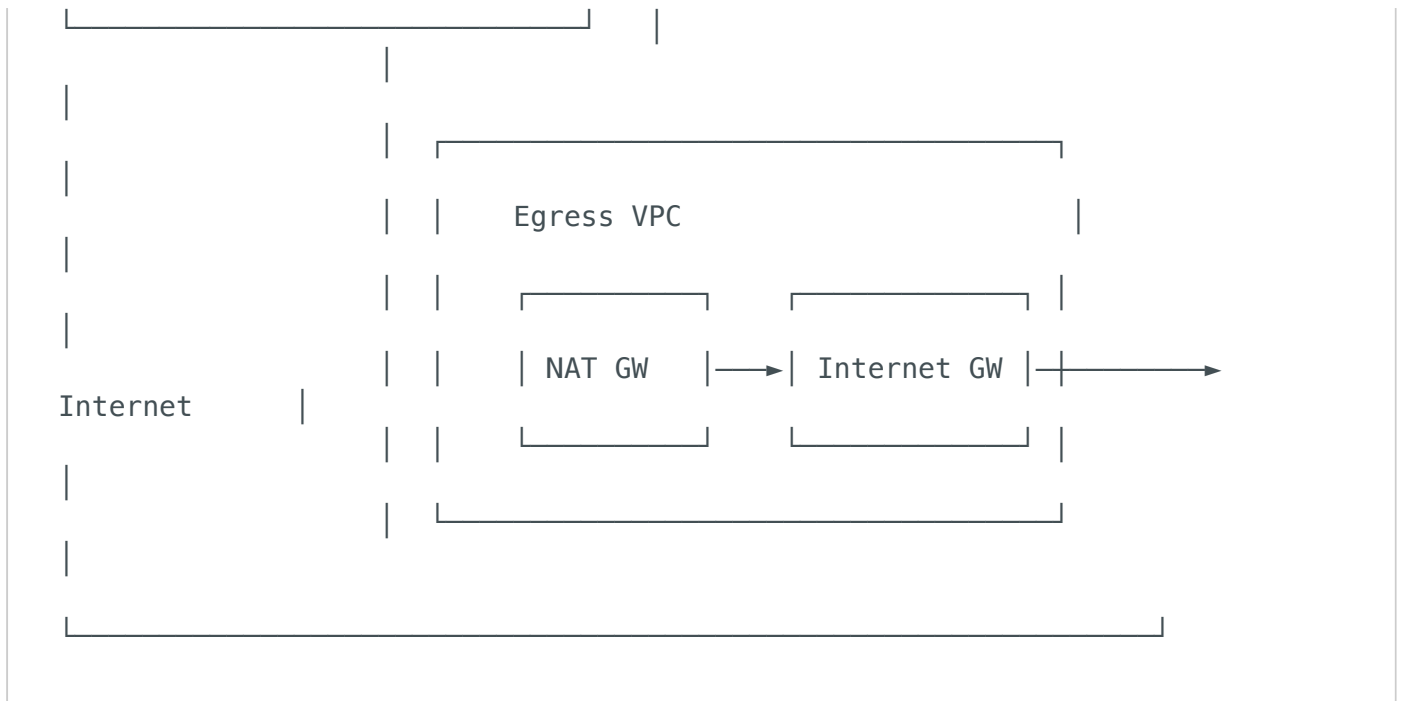
Egress VPC — Public Subnet Route Table (NAT GW's subnet)

Destination	Target	Notes
0.0.0.0/0	→ igw-xxxxxxx	NAT GW needs path to internet
10.0.0.0/8	→ tgw-xxxxxxx	Return path back through TGW

12. Full Topology Diagram







13. Key Interview Points to Memorize

#	Point	Why It Matters
1	TGW Appliance Mode	Must be enabled on Inspection VPC attachment — ensures both directions of a flow go to the same Palo Alto instance (stateful inspection)
2	GWLB uses GENEVE protocol	Not VXLAN; preserves original src/dst IP transparently — firewall sees real addresses without SNAT
3	DX is NOT encrypted by default	Always add MACsec (preferred) or IPSec over DX — critical BFSI compliance point
4	No IGW in spoke VPCs	All internet traffic flows TGW → Inspection → Egress VPC — centralized control
5	TGW Route Tables are separate from VPC Route Tables	TGW RTs control inter-attachment routing; VPC RTs control traffic within the VPC
6	Pre-Inspection RT on spoke attachments	0.0.0.0/0 → Inspection VPC — this is the traffic steering mechanism
7	Post-Inspection RT on Inspection VPC	Routes approved traffic to real destinations

#	Point	Why It Matters
	attachment	
8	Palo Alto SSL Decryption	Needs internal CA cert pushed to all endpoints so they trust re-signed certificates (via SSM / GPO)
9	Panorama	Centralized management plane — single policy set pushed to all Palo Alto instances across all regions
10	GWLB health checks	Unhealthy Palo Alto instances are automatically removed from rotation — HA built in
11	S2S VPN = 2 tunnels	Active/passive pair — if one tunnel goes down, BGP converges to second tunnel
12	Flow symmetry	For stateful firewalls: request and response MUST go through same firewall instance. GWLB 5-tuple hash + TGW Appliance Mode guarantee this

14. How to Answer in the Interview

Question: *"How do you ensure that incoming and outgoing packets are inspected and encrypted in a Hub-Spoke AWS architecture connecting OnPrem to cloud?"*

Answer:

We implement a centralized inspection architecture using AWS Transit Gateway as the hub. All spoke VPCs and OnPrem connections — via S2S VPN over IPsec IKEv2 with AES-256-GCM encryption, or Direct Connect with MACsec for Layer 2 encryption — attach to the TGW.

The traffic steering works through TGW route tables. We create a Pre-Inspection Route Table associated with all spoke VPC and OnPrem VPN/DX attachments, where the default route 0.0.0.0/0 points to the Inspection VPC attachment. This forces every packet — whether it's spoke-to-spoke east-west traffic, OnPrem-to-cloud, or cloud-to-internet — to hit the Inspection VPC first, before it reaches its destination.

Inside the Inspection VPC, we deploy Palo Alto VM-Series NGFWs in an Auto Scaling Group behind an AWS Gateway Load Balancer. The GWLB uses GENEVE

encapsulation on UDP port 6081 to transparently redirect packets to Palo Alto without modifying the original source/destination IPs. Palo Alto performs L7 App-ID inspection, IPS/IDS via Threat Prevention, SSL/TLS decryption for deep inspection of encrypted traffic, URL filtering against PAN-DB, and Wildfire sandboxing for zero-day analysis.

After inspection and approval, packets return through the GWLB back to TGW — which now uses a Post-Inspection Route Table associated with the Inspection VPC attachment, forwarding traffic to the correct spoke VPC or back to OnPrem.

We enable Appliance Mode on the TGW Inspection VPC attachment to ensure that both directions of a TCP flow go to the same Palo Alto instance — which is essential for stateful inspection correctness. Panorama provides centralized policy management across all Palo Alto instances in all regions from a single control plane.

For encryption: S2S VPN handles IPSec end-to-end, Direct Connect uses MACsec at Layer 2, Palo Alto handles TLS decryption mid-path for deep inspection then re-encrypts, and all data at rest uses KMS-backed AES-256 encryption on EBS and S3.